

NIST CSF 2.0

Step 3 — Assess Each of the 6 Functions

LearnSphere EdTech Cybersecurity Gap Assessment — Current Maturity Assessment

Document ID	LS-NIST-002	Version	1.0
Assessment Stage	Step 3 — Current Maturity Assessment	Assessment Date	07-Sep-2026
Organization	LearnSphere EdTech	Framework	NIST CSF 2.0

1. Assessment Method

Each NIST CSF 2.0 Function is assessed using four relevant Categories/Subcategories selected for LearnSphere EdTech's operating environment. Current maturity is rated using the Step 2 internal 0–4 scale: 0 Not Performed, 1 Ad Hoc, 2 Repeatable, 3 Defined, 4 Managed/Optimized.

Ratings are based on the existing/ad hoc security posture and are justified using specific in-scope systems, information types, processes and known assessment conditions. This step records **Current** maturity only; Target and Gap are established in later steps.

2. Current Maturity by Function

Function	Current Avg.	Current Posture
Govern	1.75	Ad hoc governance of children's-data requirements, consent, minimization and accountability.
Identify	1.75	Partial inventories and risk identification, with incomplete data-to-service mapping.
Protect	1.75	Existing access and protection controls, but student-record access governance needs stronger consistency.
Detect	1.75	Existing monitoring/SIEM capability with incomplete coverage measurement and event correlation.
Respond	2.00	Operational incident practices exist, but children's-data-specific handling needs standardization.
Recover	1.75	Backup/recovery capability exists, with limited scenario-based testing and improvement tracking.

3. Govern (GV) — Current Assessment

Function focus: Ad hoc governance of children's-data requirements, consent, minimization and accountability.

Category / Subcategory	Current	Current Maturity Justification
GV.OC-03 Legal, regulatory, contractual and privacy requirements are understood and managed.	1	LearnSphere handles student and minors' information through its cloud LMS, but children's-data requirements such as parental consent, purpose limitation and privacy obligations are not consistently translated into documented operational requirements.
GV.RM-01 Cybersecurity risk is managed in the context of organizational risk.	2	The organization maintains an ISMS risk register and has identified critical risks such as student-data exposure and IAM weaknesses, but risk assessment is not yet consistently triggered for every new student-data processing activity or product change.
GV.RR-02 Roles, responsibilities and authorities related to cybersecurity risk management are established and communicated.	2	Information-security responsibilities exist through the ISMS and management roles, but ownership for children's-data governance, consent and minimization is not consistently formalized across product, engineering, privacy and security activities.
GV.PO-01 Policy, processes and procedures are established and communicated to manage cybersecurity risks.	2	LearnSphere has security policies and ISMS processes, but they do not consistently translate the protection of children's data into explicit collection, consent, minimization, access and retention requirements across the LMS lifecycle.

4. Identify (ID) — Current Assessment

Function focus: Partial inventories and risk identification, with incomplete data-to-service mapping.

Category / Subcategory	Current	Current Maturity Justification
ID.AM-02 Inventories of software, services and systems are maintained.	2	The environment includes AWS infrastructure, the LMS application, databases, IAM, source-code repositories, CI/CD, monitoring and third-party services, but the inventory is not consistently linked to the student-data types and processing activities supported by each service.
ID.AM-07 Inventories of data and corresponding metadata for designated data types are maintained.	1	Student personal information and academic records are known as important assets, but an authoritative inventory with data type, owner, location, sensitivity, purpose, flow and retention metadata is incomplete.
ID.RA-04 Risk responses are identified and prioritized for identified risks.	2	LearnSphere has identified and prioritized risks such as student personal-data exposure and production-database compromise, but changes to student-data processing do not consistently trigger a structured privacy and cybersecurity risk assessment.
ID.RA-05 Threats, vulnerabilities and other factors are used to understand cybersecurity risk.	2	Existing risk assessment considers vulnerabilities and business impact, but data-minimization risk is not consistently treated as an explicit factor when new fields, processing purposes or student-data uses are introduced.

5. Protect (PR) — Current Assessment

Function focus: Existing access and protection controls, but student-record access governance needs stronger consistency.

Category / Subcategory	Current	Current Maturity Justification
PR.AA-05 Access permissions, entitlements and authorizations are defined, managed, enforced and reviewed using least privilege and separation of duties.	2	LearnSphere has IAM and privileged-access controls, but access to student records is not yet consistently governed through evidence-based least-privilege reviews, separation-of-duties checks, privileged-account certification and exception tracking.
PR.AA-03 Users, services and devices are authenticated commensurate with the risk of the access.	2	Authentication controls exist across the LMS and supporting AWS/IAM environment, but requirements vary by system and access path, leaving a need for consistently defined authentication requirements for sensitive student-record and privileged access.
PR.DS-01 The confidentiality, integrity and availability of data-at-rest are protected.	2	Production databases and backups are protected within the AWS-based environment, but protection requirements are not consistently mapped across all student-data repositories and lifecycle states with evidence of coverage.
PR.DS-10 Data is retained according to a defined policy and disposed of securely.	1	LearnSphere identifies student information and records as sensitive assets, but retention schedules, deletion mechanisms, exception handling and verification of disposal are not consistently enforced across the LMS data lifecycle.

6. Detect (DE) — Current Assessment

Function focus: Existing monitoring/SIEM capability with incomplete coverage measurement and event correlation.

Category / Subcategory	Current	Current Maturity Justification
DE.CM-01 Networks and network services are monitored to find potentially adverse events.	2	LearnSphere uses security monitoring and SIEM capabilities, but monitoring coverage for critical AWS, LMS and student-data environments is not consistently measured against defined coverage expectations.
DE.CM-06 External service providers are monitored to find potentially adverse events.	2	Relevant third-party dependencies such as AWS and other service providers are recognized in the ISMS, but monitoring expectations and evidence requirements are not consistently defined for every provider supporting the in-scope environment.
DE.AE-02 Potentially adverse events are analyzed to better understand associated activities.	2	Alert investigation is performed, but metrics such as MTTD/MTTI and consistent investigation evidence are not yet used across the monitoring process to demonstrate repeatable analysis performance.
DE.AE-04 The impact of adverse events is determined.	1	Security events can be investigated through application, IAM and monitoring data, but correlation between IAM activity, application activity and access to student records is not consistently defined to establish impact quickly.

7. Respond (RS) — Current Assessment

Function focus: Operational incident practices exist, but children's-data-specific handling needs standardization.

Category / Subcategory	Current	Current Maturity Justification
RS.MA-01 Incidents are managed with documented response processes.	2	Incident response practices exist, but severity and handling criteria do not consistently distinguish incidents involving children's or student data from other security events.
RS.AN-03 Analysis is performed to establish what has occurred during an incident.	2	Logs and security evidence are available from the LMS, AWS/IAM and monitoring environment, but evidence collection and analysis for suspected unauthorized student-record access are not standardized through a dedicated workflow.
RS.CO-02 Internal and external stakeholders are notified of incidents according to established criteria.	2	Escalation and management communication exist through the ISMS, but specific communication roles, decision points and notification expectations for student-data incidents are not consistently documented.
RS.MI-01 Incidents are contained to prevent expansion and additional impact.	2	Containment activities are supported by IAM, application and infrastructure controls, but predefined playbooks for compromised student records and related access scenarios are incomplete.

8. Recover (RC) — Current Assessment

Function focus: Backup/recovery capability exists, with limited scenario-based testing and improvement tracking.

Category / Subcategory	Current	Current Maturity Justification
RC.RP-01 Recovery plans are executed during or after a cybersecurity incident.	2	LearnSphere has backup and recovery capabilities for its AWS-hosted LMS and production data, but recovery exercises are not consistently scenario-based for ransomware, database compromise or student-data loss.
RC.RP-03 Recovery activities are conducted according to defined priorities and dependencies.	2	Critical services and data are recognized, but recovery priorities and technical dependencies are not consistently documented against defined RTO/RPO expectations for the LMS and student-data environment.
RC.CO-02 Recovery activities are communicated to internal and external stakeholders.	2	Recovery communication is part of continuity planning, but specific communication requirements for student-service disruption and recovery milestones are not consistently defined.
RC.IM-01 Recovery plans and processes incorporate lessons learned and are updated.	1	Post-incident and exercise learning is available informally, but lessons learned are not systematically converted into tracked, owned and verified improvement actions.

10. Overall Current-State Conclusion

Overall current maturity: 1.79 / 4.00. LearnSphere EdTech demonstrates an existing cybersecurity foundation through its AWS environment, LMS controls, IAM, source-code protection, backups and security monitoring. However, the posture remains predominantly ad hoc to repeatable, with the most material weaknesses concentrated around children’s-data governance, authoritative student-data inventory, student-record access governance, lifecycle controls and detection correlation.

The assessment supports moving to Step 4 — Target Maturity, where realistic target levels will be assigned to each selected outcome based on risk, sensitivity of student information, regulatory exposure, operational capability and the need for measurable improvement.

11. Approval

ROLE	NAME	SIGNATURE	DATE
Prepared By	Mr. Meejan Shaikh – GRC Analyst	_____	07-Sep-2026
Reviewed By	Information Security Manager	_____	07-Sep-2026
Approved By	CISO	_____	07-Sep-2026

Step 3 output: a documented Current Profile assessment covering four relevant outcomes under each of the six NIST CSF 2.0 Functions, with evidence-based company-specific justification for every rating.